PIC – Unified Platform Design: one menu, one sign-in, buyer and supplier enterprise accounts

AlphaHelion Supplier Capability Digital Twin and Purchasing Intelligence Cloud (PIC) as a single platform.

Date: 10 November 2026. Code baseline: `main` at commit `92c4426`. Status: **proposal for approval**, no code changed yet. Written for: the product owner and the implementation team.

1. What is asked

1. **One sidebar** with every menu item of the Supplier Capability Digital Twin ("the twin") and of PIC, on every page.
2. **One sign-in page** for buyers and suppliers.
3. **Enterprise account registration** where the company chooses **buyer** or **supplier**.

Decisions taken (10 November 2026):

#	Question	Decision
D-U1	Which buyer does a registering supplier join?	**Independent supplier**: the supplier company gets its own account, not tied to any buyer, and connects to buyers later
D-U2	How is a buyer organisation created?	**Request, then operator approval**: self-service form, e-mail verified, a platform operator approves, the first administrator gets the activation link
D-U3	What does sign-in ask for?	**E-mail and password only**; the organisation is found from the e-mail; a person in several organisations picks one; two-step verification and SSO stay
D-U4	Twin screens in production?	**Hidden in production**; shown in demo and test environments (they run on placeholder data)

2. How it works today (facts from the code)

Area	Twin (original)	PIC
Sign-in page	`/login`: placeholder. No password check; an e-mail containing "supplier" opens the supplier screens	`/pic/login`: real. Organisation code + e-mail + password, two-step verification (TOTP), SSO per organisation, session cookie `pic_session` (8 h), revocable server-side
Registration	`/register`: placeholder. Buyer/supplier choice is kept in the browser only	Supplier only, by invitation link (`/pic/register?token=`); buyer organisations are created by an operator from the command line (`tools/tenant_admin.py`)
Organisation	Legacy table `tenants` with type BUYER/SUPPLIER (`backend/app/models/tenant.py`)	`pic.tenant`: code, name, template. **No type, no status.** Not under row-level security
User	Legacy `users`, e-mail unique globally	`pic.app_user`: **e-mail unique per organisation only**; password, roles, attributes, MFA per organisation
Supplier login	Persona switch in the browser	A `SUPPLIER_USER` is an `app_user` **inside the buyer's organisation**, linked to that buyer's `supplier` row (`supplier_id`). Portal data is filtered by that link in the API
Sidebar	`components/layout/Shell.tsx` (own menu; since today also lists the PIC items)	`components/pic/WorkspaceShell.tsx`
Production	Twin screens and their API are switched off (`PIC_ENABLE_LEGACY_DEMO`, `frontend/src/proxy.ts`)	Everything on

Isolation between organisations is enforced by the database (forced row-level security on every tenant table). That stays the backbone of the design.

3. Target design

3.1 Organisations get a type and a status

`pic.tenant` gains:

Column	Values	Meaning
`kind`	`BUYER`, `SUPPLIER`	What the organisation is. Existing tenants become `BUYER`
`status`	`PENDING_VERIFICATION`, `PENDING_APPROVAL`, `ACTIVE`, `REJECTED`, `SUSPENDED`	Life cycle of a self-registered organisation. Existing tenants become `ACTIVE`
`registered_by_email`, `registered_at`, `approved_by`, `approved_at`, `decision_reason`		Audit of the registration

A **supplier organisation** is a tenant of kind `SUPPLIER`. It holds the supplier's own company profile (legal name, GSTIN, PAN, address, bank details, certificates, capabilities) and its own users, isolated by the same row-level security as any buyer.

3.2 One identity per person (new)

A person signs in once with e-mail and password and may belong to several organisations (a buyer employee, a supplier employee, a consultant working for two clients).

New global tables, not reachable by the application role directly; only through narrow, audited database functions:

Table	Content
`pic.identity`	One row per person: e-mail (unique, lower-case), password hash, status, e-mail verified at, failed-attempt counters, MFA factor
`pic.identity_membership`	Identity ↔ organisation ↔ `app_user` of that organisation. Roles and attributes stay on the `app_user`, inside the organisation

Password and two-step verification move from `app_user` to `identity`. `app_user` keeps what the organisation decides: roles, attributes, active flag, session version.

Migration of existing users: on the first sign-in after release, the e-mail and password are checked against the existing `app_user` rows of that e-mail; the matching ones are linked to a new identity that takes over the password hash and MFA factor. Users with the same e-mail in several organisations and **different passwords** are asked to confirm each organisation with its password once. Nothing is lost and nobody has to reset a password.

3.3 One sign-in page

Route `/signin` (the old `/login` and `/pic/login` redirect to it).

1. E-mail and password. The answer never tells whether an e-mail exists (same message and timing for "unknown e-mail" and "wrong password").
2. Two-step verification if the identity has a factor, or enrolment if any of the person's roles requires it (rule `MFA` of each organisation).
3. Organisation choice: one membership → straight in; several → a picker showing organisation name, type (buyer / supplier) and role. The picker is also in the header, so a person can switch organisation without signing in again.
4. Landing page: buyer organisation → PIC command centre; supplier organisation → supplier workspace home.

SSO: the e-mail domain decides. If the domain belongs to an organisation with SSO, the page offers "Continue with SSO" after the e-mail is typed. The session keeps today's controls: 8-hour token, revocation by session version, role-change detection.

3.4 Registration with the buyer / supplier choice

Route `/register` (public). Step 1: **"I am a buyer"** or **"I am a supplier"**.

Buyer organisation (D-U2):

1. Form: company name, country, industry template, work e-mail, contact name, phone, GSTIN (optional at this stage), expected users.
2. E-mail verification link (single use, 24 h). Free-mail domains (gmail.com and similar) are refused for buyers.
3. Status `PENDING_APPROVAL`. A **platform operator** (new platform-level role, not part of any customer organisation) reviews the request in the operator console: company, domain, duplicates of an existing organisation, sanctions screening of the company name.
4. Approve: the existing provisioning code runs (`tenant_admin.create` : number ranges, rule sets, SoD rules, agents, company code, plant), the registrant becomes the first administrator and gets the activation e-mail (password, two-step verification). Reject: reason recorded and e-mailed.

Supplier organisation (D-U1):

1. Form: legal name, country, GSTIN and PAN (India) or tax ID (abroad), address, work e-mail, contact, password, main categories and capabilities.
2. E-mail verification link. GSTIN format, check digit, state and the PAN inside the GSTIN are validated (same rules as today's supplier registration).
3. Duplicate check across the network: a **network-wide** blind index of GSTIN and PAN (new key, separate from the per-buyer indexes) stops a second registration of the same company. The registrant is told to ask the existing account's administrator for access.
4. Sanctions screening. A clear result activates the supplier organisation at once (`ACTIVE`); a possible match goes to the platform operator (`PENDING_APPROVAL`).
5. The registrant becomes the supplier organisation's administrator and can invite colleagues.

3.5 Connecting a supplier to buyers

A **connection** links a supplier organisation to a buyer organisation. It is the only thing that lets data cross from one organisation to another, and it carries the supplier's consent.

Way	Flow
Supplier asks	Supplier searches the buyer directory (buyers that opted in to "accept connection requests") or enters the buyer's organisation code, picks categories and sends a request. The buyer's supplier manager accepts or declines
Buyer invites	Buyer's supplier manager invites by e-mail (today's invitation). If the e-mail or GSTIN already has a supplier organisation, the invitation becomes a connection request to it; otherwise the invitee registers a supplier organisation first

On **acceptance**, inside the buyer organisation:

1. A `supplier` row is created (or the existing one is linked) with a reference to the supplier organisation, filled from the profile the supplier shared (legal name, GSTIN, PAN, address; bank details only as a **bank change request** so the buyer's call-back and dual approval still apply).
2. The buyer's normal onboarding runs unchanged: screening, bank call-back, two finance approvals, qualification per category, ERP vendor creation.
3. For each supplier user the supplier administrator allows for this buyer, a membership is created with an `app_user` of role `SUPPLIER_USER` and `supplier_id` = the buyer's supplier row. **All existing portal screens and their supplier-level filters keep working without change**, because they still see a supplier user of that buyer.

Profile changes made later by the supplier (address, contacts, tax IDs, bank) reach each connected buyer as a **master-data change request** (today's `SMC-` and `BCR-` approvals), never as a direct overwrite.

The supplier can end a connection; the buyer keeps its records (audit, documents), and the supplier users lose access to that buyer.

3.6 One sidebar and one shell

One shell component replaces `Shell.tsx` and `WorkspaceShell.tsx` on every page:

- **Header:** organisation switcher (name, type, role), live indicator, notifications, account, sign out.
- **Menu by organisation type**, from one menu definition (`components/nav/picNavigation.ts` , extended):

Organisation	Groups
Buyer	Decide · My work · Plan & request · Source & contract · Order to pay · Govern (PIC), then **Supplier capability twin** (twin buyer screens: supplier network, discovery, generative DFSC, Monte Carlo, evidence vault, risk command and others)
Supplier	Home · Company profile & capabilities · Buyer connections · My work (tasks, notifications, account) · Per connected buyer: RFQs and bids, orders and confirmations, ASNs, service entries, invoices and payments, contracts (the PIC portal) · **Supplier capability twin** (my digital twin, machine telemetry, transit, ESG, development & CAPA)

- Role filters stay as they are. Twin items are shown only where the twin screens are switched on (D-U4); production shows none.
- The twin persona switch ("Buyer portal / Supplier portal") is removed: the organisation type decides.

4. Security controls

Risk	Control
Account and e-mail enumeration	Identical answers and timing for unknown e-mail and wrong password; registration answers "check your e-mail" in every case
Password guessing	Per-identity and per-IP limits, progressive delay, lock after repeated failures with e-mail notice; breached-password check (today's rule)
Fake buyer organisations	E-mail verification, no free-mail domains, operator approval, sanctions screening, audit of every decision
Fake or duplicate suppliers	E-mail verification, GSTIN/PAN validation, network-wide duplicate check, sanctions screening; buyers still qualify every supplier
Data leaking between organisations	Row-level security unchanged; global identity tables reachable only through audited database functions; data crosses only through an accepted connection, and only the fields listed in §3.5
Bank fraud through profile changes	A supplier's bank change reaches buyers only as a bank change request: call-back by a second person, two finance approvals, 72-hour cooling-off (unchanged)
Session theft	httpOnly cookies, 8-hour tokens, server-side revocation; switching organisation issues a new token for that organisation only
Operator misuse	Operator role separate from customer roles, MFA mandatory, every action in a platform audit chain

5. Delivery plan

Phase	Content	Database change	Estimate
1	**One shell and sidebar** on every page (buyer menu, twin items in demo only); persona switch removed; legacy `/login` and `/register` redirect to the PIC pages	none	2–3 days
2	**Sign-in by e-mail**: global identity and memberships, credential migration on first sign-in, organisation picker and switcher, SSO by e-mail domain, `/signin` page	migration 0029 (identity, membership, tenant kind and status)	5–7 days
3	**Buyer registration**: `/register` with the choice, e-mail verification, operator role and console, approval running the existing provisioning	migration 0030 (registration requests, operator audit)	4–5 days
4	**Supplier organisations**: supplier registration, company profile and capabilities, colleague invitations, supplier home and menu	migration 0031 (supplier organisation profile, network blind index)	6–8 days
5	**Connections**: buyer directory, requests and invitations, acceptance creating the buyer-side supplier and portal access, change requests to connected buyers, ending a connection	migration 0032 (connections, shared-field consent)	7–9 days
6	Twin supplier screens on the supplier organisation's own data (they use placeholder data today); documents (Workflow Guide, screens) updated	per screen	to be sized after phase 5

Each phase ends with tests (unit, API, row-level-security leak tests between organisations), a CI run and a deploy to Neon, with your approval before each push as today. Phases 1 and 2 can be used on their own; phases 3–5 build on 2.

6. What you need to supply

1. **Platform operators:** names and e-mails of the people who approve buyer organisations (they need an authenticator app).
2. **E-mail sending:** SMTP server, sender address and domain (SPF/DKIM) for verification, activation and decision e-mails. Today `PIC_SMTP_HOST` is optional; it becomes mandatory.
3. **Public URL** of the platform for the links in e-mails.
4. **Legal texts:** terms of use and privacy notice shown at registration, and the consent text for sharing a supplier profile with a buyer.
5. **Buyer directory policy:** may buyers be listed for suppliers to find, or only reachable by organisation code?
6. **Free-mail list** to refuse for buyers, and whether suppliers may register with free-mail addresses (many small Indian suppliers use them).
7. **GSTIN verification provider** (optional): an API to confirm a GSTIN is active with the tax system; without it only the format and check digit are verified.
8. **Existing demo supplier logins** (for example `tf.sales@axion.example`): keep them as buyer-side supplier users, or move them into supplier organisations in phase 5.

7. Open points for the product owner

1. Does a supplier organisation need operator approval like a buyer, or is a clean screening enough (the proposal)?
2. Who in a supplier organisation decides which colleagues get access to which buyer: only its administrator (the proposal) or each user?
3. Should a buyer see a supplier's network profile before a connection is accepted (search with name, location, categories only), or nothing until the supplier connects?